CLOUD & CYBERSECURITY | RESEARCH + PROTOTYPE

SYSTEM DESIGN DOCUMENT

Risk-Adaptive Zero-Trust Security Architecture for Hybrid Cloud Infrastructure

Module design: architecture, components, workflows, data model and evaluation plan

Prepared by	Farhaan Pasha (SRN R23EK009)
Faculty guide	Mr Hidam Rameshwar Singh
Center	Center for Emerging Computing Technologies
Project type	Research + Prototype (Design, Implementation, Evaluation)
Status	Design baseline v1.0 for implementation

Version 1.0 | October 2026

Contents

1. Introduction and Scope . . . 3
2. Requirements . . . 3
3. Architecture Overview . . . 4
4. Zero-Trust Logical Architecture . . . 4
5. Identity and Access Control Design . . . 5
6. Behavioural Data Collection . . . 6
7. Behavioural Anomaly Detection Module . . . 6
8. Risk-Adaptive Access Control Engine . . . 7
9. Access Request Workflow . . . 8
10. Data Model . . . 10
11. Interface (API) Design . . . 10
12. Security Monitoring and Alerting . . . 10
13. Attack Simulation and Evaluation . . . 11
14. Implementation Plan and Traceability . . . 11
15. Risks and Limitations . . . 12

1. Introduction and Scope

This document specifies the system design of the **Risk-Adaptive Zero-Trust Security** module for a hybrid cloud prototype. Instead of trusting users or devices because they sit inside a network perimeter, the module evaluates every access request using identity, device, behavioural and resource context, assigns a risk level, and enforces one of four decisions: **Allow, Challenge, Restrict or Block**.

1.1 Design principles

- **Never trust, always verify:** network location grants nothing; each request is authenticated and authorised.
- **Least privilege:** access is limited to what a role needs on a given resource.
- **Assume breach:** behaviour is monitored continuously, even for authenticated sessions.
- **Adaptive response:** the strength of the response follows the calculated risk, so low-risk users are not burdened.
- **Fail-safe defaults:** if the decision service is unreachable, sensitive resources are denied and low-sensitivity ones use a cached decision.
- **Auditability and explainability:** every decision is logged with a score and reason codes.

1.2 Scope

In scope	Out of scope
Private + public cloud prototype on VMs / cloud instances; identity and access control; behavioural anomaly detection; risk engine and policy engine; central logging; attack simulation inside the project environment; evaluation of accuracy, false-positive rate, overhead and latency.	Production-grade high availability; commercial cost optimisation; testing against any external or unauthorised system; hardware security modules; large-scale (enterprise) load testing.

2. Requirements

2.1 Functional requirements

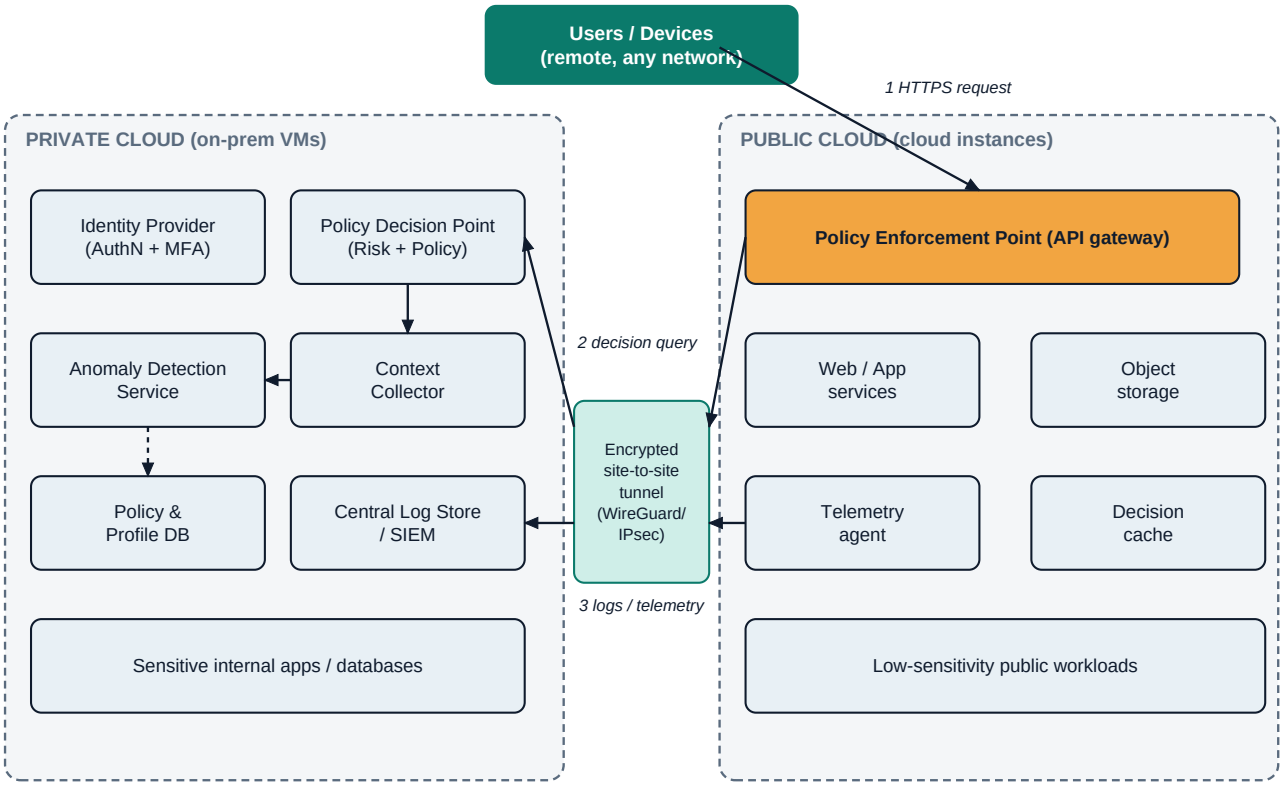
ID	Requirement
FR1	Authenticate users and devices (credentials + MFA, signed tokens) for every access request.
FR2	Enforce least-privilege policies per role, resource and action.
FR3	Collect device, session and request context for each request.
FR4	Compute a behavioural anomaly score from per-user / per-role baselines.
FR5	Combine signals into a risk score and return Allow, Challenge, Restrict or Block.
FR6	Support step-up authentication (Challenge) and re-evaluation after it.
FR7	Log every request and decision centrally; raise alerts and show a dashboard.
FR8	Provide a controlled attack-simulation harness for the isolated testbed.
FR9	Export evaluation metrics (accuracy, FPR, FNR, overhead, latency, availability).

2.2 Non-functional requirements

Attribute	Requirement (targets are initial and validated in Phase 7)
Performance	Decision response time kept low enough not to degrade service latency noticeably; target p95 under 100 ms for the decision call.
Security	TLS on all channels, signed short-lived tokens, encrypted tunnel between clouds, tamper-evident logs.
Availability	Stateless decision service that can run as multiple instances; decision cache at the gateway.
Explainability	Each decision stores the contributing signals and reason codes.
Privacy	Logs hold identifiers and behavioural features only; no passwords or payload contents.
Reproducibility	All configuration, policies and experiments are version-controlled in Git.

3. Architecture Overview

The prototype is a hybrid cloud with a **private cloud** (on-premises VMs) hosting the identity, decision, analytics and logging services, and a **public cloud** hosting the enforcement gateway and application workloads. The two sides communicate over an encrypted, monitored site-to-site tunnel. All user traffic enters through the Policy Enforcement Point (PEP), which asks the Policy Decision Point (PDP) for a verdict before forwarding.



Every request is verified at the PEP; no implicit trust is granted for network location.

Figure 1: Hybrid cloud deployment architecture

3.1 Network zones and addressing

Addressing is illustrative; final values are recorded as part of Phase 1 documentation.

Zone	Location	Subnet	Hosts / services
Control	Private	10.10.1.0/24	Identity Provider, PDP (risk + policy), anomaly service, context collector
Data	Private	10.10.2.0/24	Sensitive databases and internal apps, SIEM / log store, policy and profile DB
Edge / App	Public	10.20.1.0/24	API gateway (PEP), web / app services, telemetry agent
Storage	Public	10.20.2.0/24	Object storage and low-sensitivity workloads
Tunnel	Between clouds	10.99.0.0/30	Encrypted site-to-site link (WireGuard or IPsec), only required ports allowed

4. Zero-Trust Logical Architecture

The design follows the standard Zero Trust split of enforcement and decision. The PEP never decides by itself; the PDP gathers signals from the Policy Information Points (PIPs), computes risk and returns a decision that the PEP enforces.

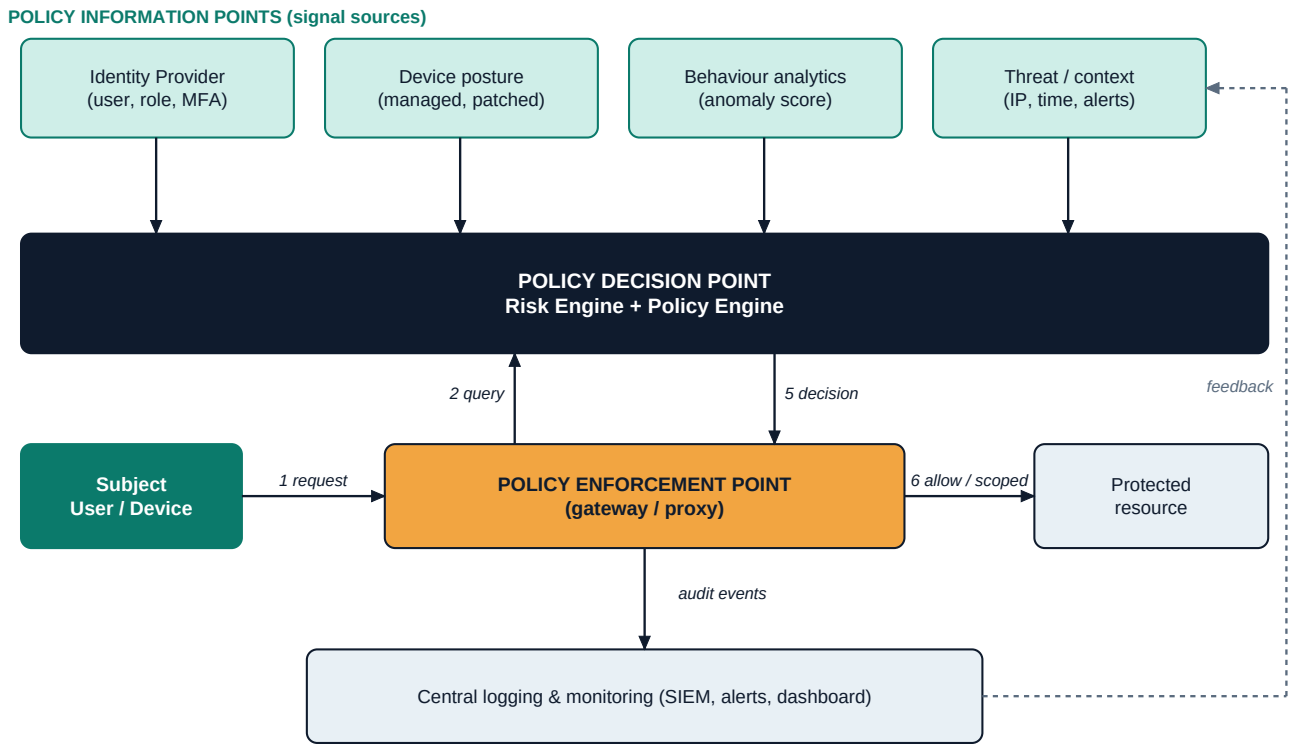


Figure 2: Zero-Trust logical components and data flow (steps 3 and 4: signals are gathered from the PIPs and risk is scored)

Component	Responsibility	Candidate implementation
Identity Provider	Authenticates users, issues signed tokens, manages MFA and roles	Keycloak (OIDC / OAuth2, TOTP MFA)
Policy Enforcement Point	Intercepts every request, calls the PDP, enforces the verdict, caches decisions briefly	API gateway / reverse proxy with auth hook (e.g. Nginx or FastAPI middleware)
Context Collector	Gathers device posture, session, IP and request attributes	Python service + endpoint agent data
Anomaly Engine	Builds baselines, scores each request 0 to 1	Python, scikit-learn (Isolation Forest)
Risk + Policy Engine (PDP)	Combines signals into risk R, applies policies and overrides	Python REST service (FastAPI)
Policy / Profile DB	Stores roles, policies, baselines, decisions	PostgreSQL
Logging & Monitoring	Central logs, alerts, dashboards	Fluent Bit / Filebeat, OpenSearch or Loki, Grafana

5. Identity and Access Control Design

Entities are users, devices, applications and cloud resources. Authentication happens first; authorisation then combines a role-based baseline (least privilege) with the live risk decision, so a valid role is necessary but never sufficient.

5.1 Role and resource matrix (initial policy)

Role	Public app (low)	Internal API (medium)	Sensitive DB (high)	Admin console (critical)
Admin	Read / write	Read / write	Read / write, MFA	Read / write, MFA + managed device
Engineer	Read / write	Read / write	Read, MFA	No access
Analyst	Read	Read	Read, MFA	No access
Contractor	Read	No access	No access	No access

5.2 Access rules

- Tokens are short-lived (for example 15 minutes) and bound to the device; a request is re-evaluated each time, not once per session.
- Devices must be registered; unmanaged or unpatched devices raise the device risk score.
- Policies are data (rows in the policy store), versioned in Git, and changed through an audited API.
- Deny by default: a request with no matching policy is blocked.

6. Behavioural Data Collection

Access and authentication logs are collected from the gateway and identity provider, normalised into one schema, and turned into features per request and per time window.

Feature	Source	Meaning
hour_of_day, day_of_week	Auth log	Time pattern of access
login_frequency	Auth log	Logins per user per window
failed_attempts	Auth log	Consecutive and windowed authentication failures
distinct_resources	Gateway log	Number of different resources touched in a window
request_rate, bytes_out	Gateway log	Request volume and data transferred
new_ip / new_device	Context collector	Source IP or device not seen in the baseline
session_duration	Gateway log	Length and gaps of sessions
sensitive_access_ratio	Gateway log	Share of requests to high-sensitivity resources

Datasets: (a) logs generated from scripted normal user behaviour on the prototype, (b) synthetic anomalies injected for labelled evaluation. Data is split into training and held-out test sets; the split ratio is fixed before experiments begin.

7. Behavioural Anomaly Detection Module

Compared against One-Class SVM / LOF as alternative detectors

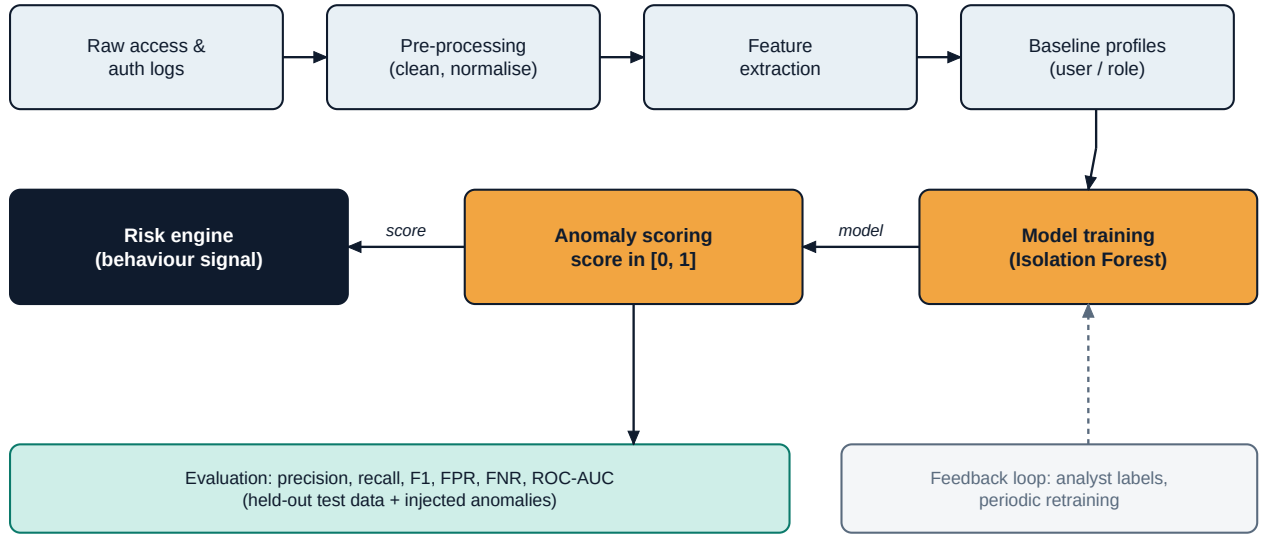


Figure 3: Anomaly detection pipeline

- **Baselines:** one profile per user, with a role-level profile as fallback for new users (cold start).
- **Primary model:** Isolation Forest, chosen for unsupervised use with unlabelled normal data; One-Class SVM and Local Outlier Factor are compared as alternatives.
- **Score:** the model output is normalised to the range 0 to 1 (higher means more anomalous) and returned with the top contributing features.

- **Drift handling:** scheduled retraining on recent confirmed-normal data; analyst feedback on false positives is added to the training set.
- **Metrics:** precision, recall, F1, false-positive rate, false-negative rate and ROC-AUC on held-out data.

8. Risk-Adaptive Access Control Engine

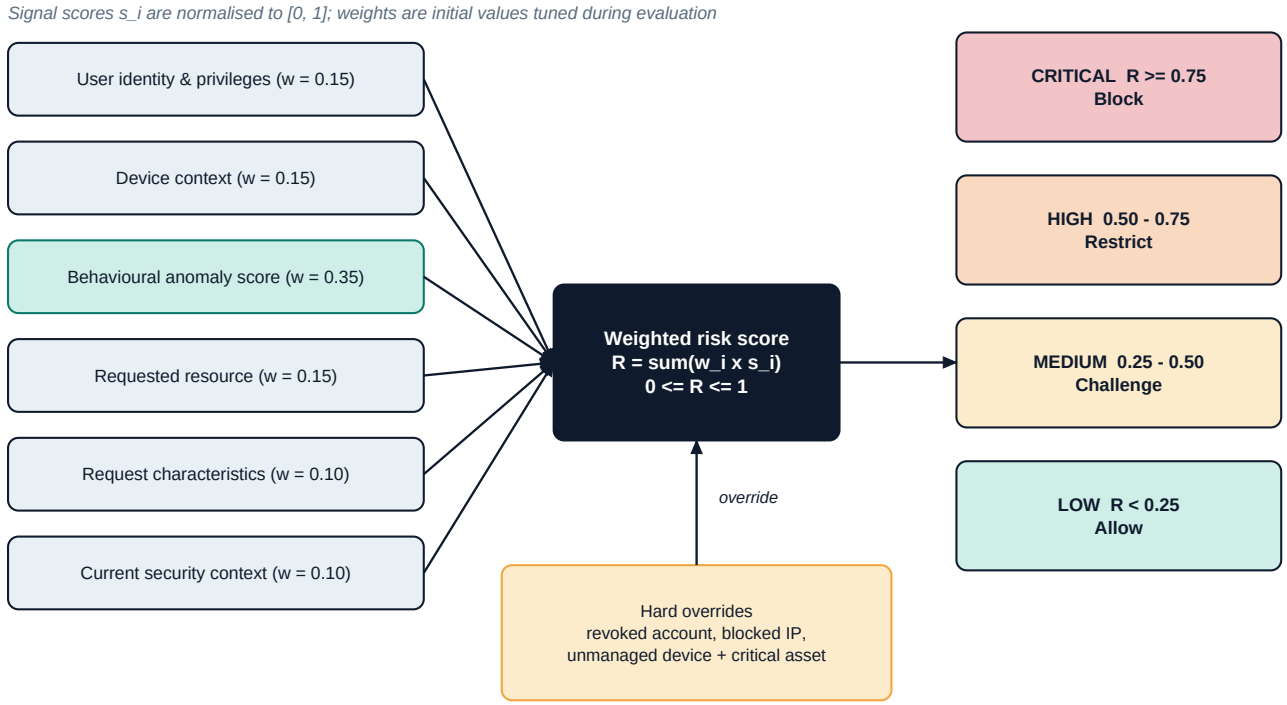


Figure 4: Risk score composition and decision thresholds

Each signal is converted to a score between 0 and 1 and combined as **R = 0.15 U + 0.15 D + 0.35 B + 0.15 Rs + 0.10 Q + 0.10 C**, where U is user identity and privilege, D is device, B is behavioural anomaly, Rs is resource sensitivity, Q is request characteristics and C is security context. Weights and thresholds are initial values to be tuned against false-positive and false-negative results.

Signal	Example scoring (initial)
U: user / privilege	Higher for admin roles or users without MFA; lower for standard roles with MFA
D: device	Managed and compliant 0.0; managed but unpatched 0.5; unmanaged or unknown 1.0
B: behaviour	Normalised anomaly score from the model
Rs: resource	Low 0.2, medium 0.5, high 0.8, critical 1.0
Q: request	Unusual method, volume or rate relative to the profile
C: context	Off-hours, new IP or location, IP reputation, active alerts for the user

Risk level	Range of R	Decision	Behaviour
Low	R below 0.25	Allow	Grant access per policy
Medium	0.25 to below 0.50	Challenge	Require step-up MFA, then re-evaluate
High	0.50 to below 0.75	Restrict	Grant reduced scope (read-only, no sensitive resources), raise alert
Critical	0.75 and above	Block	Deny, terminate session, alert, require analyst review

8.1 Worked examples

Case	U / D / B / Rs / Q / C	R	Decision
Engineer, managed laptop, usual hours, internal API	0.3 / 0.0 / 0.1 / 0.5 / 0.1 / 0.1	0.175	Allow
Engineer, new unmanaged device, 02:00, sensitive DB	0.3 / 1.0 / 0.8 / 0.8 / 0.5 / 0.7	0.715	Restrict

Hard overrides take precedence over R: revoked accounts and blocked IPs are always blocked, and unmanaged devices can never exceed Restrict on critical assets. Each decision returns reason codes such as `NEW_DEVICE` or `OFF_HOURS` so it can be explained and audited.

9. Access Request Workflow

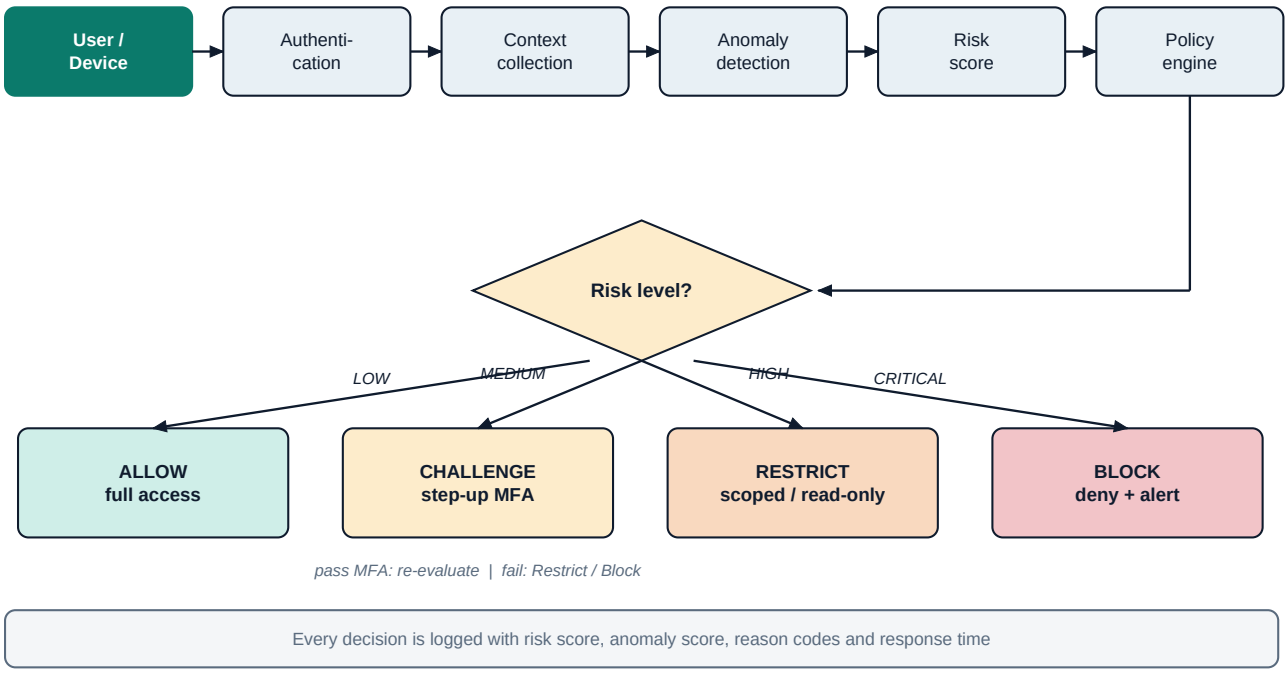


Figure 5: End-to-end access decision workflow

The workflow matches the proposed system flow: User / Device, Authentication, Context Collection, Anomaly Detection, Risk Score, Policy Engine and Access Decision. For a Challenge, the user completes step-up MFA and the request is scored again; failure moves the decision to Restrict or Block.

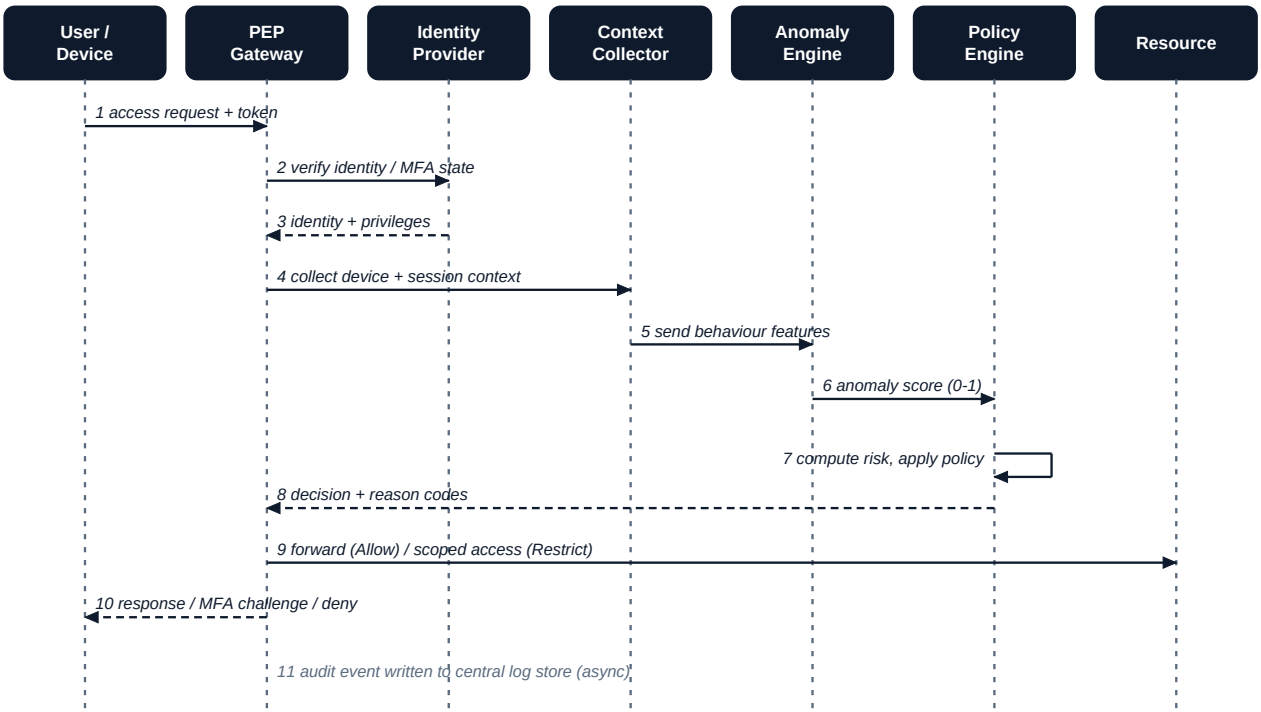
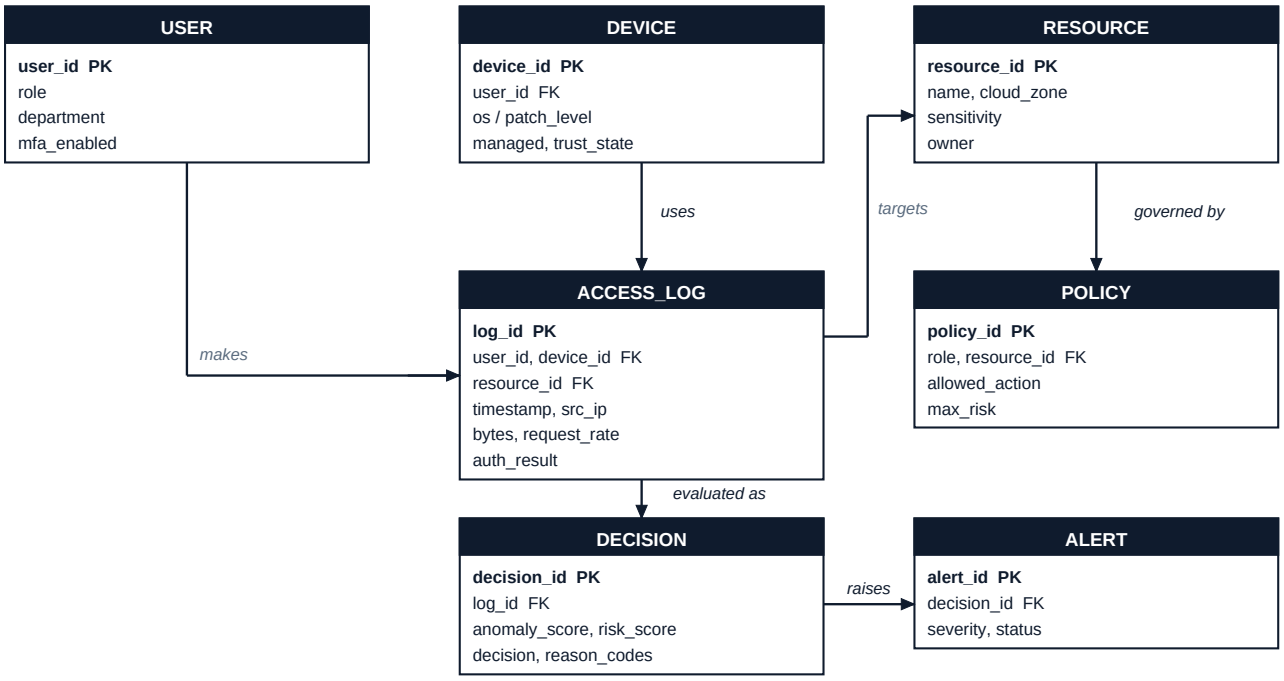


Figure 6: Sequence diagram of a single access request

9.1 Failure handling

- PDP unreachable: the PEP denies sensitive resources and applies a short-lived cached decision to low-sensitivity ones; the event is alerted.
- Anomaly engine unavailable: behaviour score defaults to a conservative mid value and the decision is flagged as degraded.
- Identity provider unavailable: no new sessions are issued; existing tokens expire on schedule.

10. Data Model



PK = primary key, FK = foreign key. ACCESS_LOG is the central fact table; DECISION is 1:1 with each evaluated request.

Figure 7: Logical data model

11. Interface (API) Design

Endpoint	Method	Purpose
/auth/login, /auth/mfa/verify	POST	Authenticate and complete step-up challenge
/access/evaluate	POST	PEP asks the PDP for a decision on a request
/anomaly/score	POST	Return anomaly score and top features for a feature vector
/risk/{request_id}	GET	Explain a past decision (signals, weights, reason codes)
/policies, /policies/{id}	GET / PUT	Read and update policies (audited)
/logs, /alerts	GET	Query logs and alerts for the dashboard
/sim/run	POST	Start an attack scenario (testbed only, disabled elsewhere)
/metrics	GET	Evaluation and latency metrics

```
POST /access/evaluate
{ "user_id": "u102", "device_id": "d77", "resource_id": "db-finance",
  "action": "read", "src_ip": "203.0.113.25", "ts": "2026-10-22T02:04:11Z" }

200 OK
{ "decision": "RESTRICT", "risk": 0.715, "anomaly": 0.80,
  "reason_codes": ["NEW_DEVICE", "OFF_HOURS", "SENSITIVE_RESOURCE"],
  "latency_ms": 41 }
```

12. Security Monitoring and Alerting

- **Central logging:** gateway, identity, decision and system logs are shipped to one store with synchronised time and integrity protection.
- **Alerts:** any Block decision; repeated failed Challenges; sudden rise in a user's risk score; PDP degraded mode; policy changes.
- **Dashboard:** decisions per level, top reason codes, anomaly score distribution, decision latency, active alerts.

- **Retention:** raw logs kept for the project duration; aggregated metrics kept for the final report.

13. Attack Simulation and Evaluation

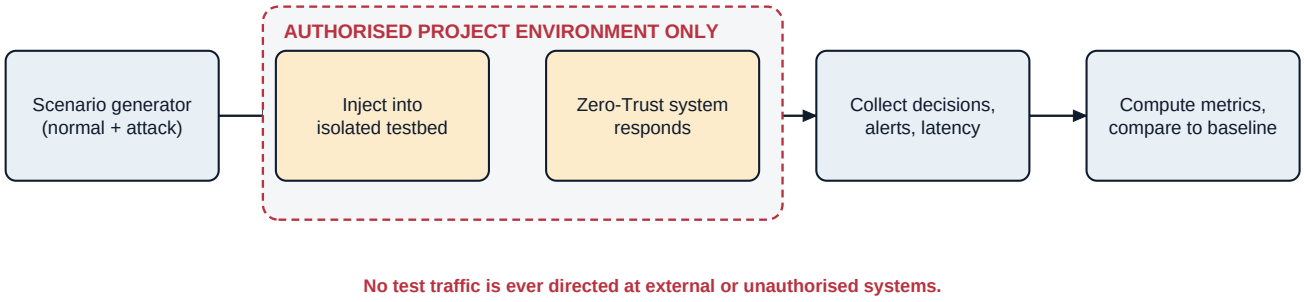


Figure 8: Attack simulation and measurement workflow

All simulations run only inside the authorised project environment. No test is performed against external or unauthorised systems.

Scenario	Description	Expected response
Credential stuffing / brute force	Many failed logins from one or several sources	Rising risk, Challenge then Block
Stolen token, new device	Valid token used from an unregistered device	Challenge or Restrict
Off-hours / unusual location	Legitimate user at atypical time or IP	Challenge
Privilege probing	Low-privilege user requests many sensitive resources	Restrict, alert
Data exfiltration pattern	Sudden large volume of reads or transfers	Restrict or Block, alert

Metric	Definition / how measured
Detection accuracy	(TP + TN) / (TP + TN + FP + FN) on labelled normal and attack requests
False-positive rate	FP / (FP + TN): legitimate requests wrongly challenged or blocked
False-negative rate	FN / (FN + TP): attacks that were allowed
Authentication overhead	Mean login time with the Zero-Trust flow minus baseline login time
Decision response time	Time from PEP query to verdict (mean and p95)
Service latency	End-to-end request latency with and without the module
Availability / reliability	Share of requests served correctly over the test period, including degraded-mode behaviour

Results from normal operation are compared with simulated attack runs, and the proposed system is compared with a static access-control baseline. Each experiment is repeated several times and reported as mean and p95.

14. Implementation Plan and Traceability

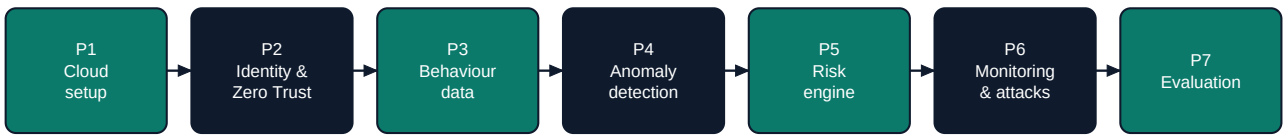


Figure 9: Implementation roadmap

Deliverable	Design section
Architecture design	Sections 3 and 4 (Figures 1, 2)
Cloud prototype	Section 3.1 (zones and addressing)
Identity and access control	Section 5
Anomaly detection	Sections 6 and 7 (Figure 3)
Risk-adaptive engine	Sections 8 and 9 (Figures 4, 5, 6)
Security evaluation	Section 13 (Figure 8)
Final documentation	This document, source repository, results and presentation

15. Risks and Limitations

Risk	Mitigation
PDP or policy store compromise	Network isolation, signed policy updates, least-privilege service accounts, audit alerts
Token theft	Short lifetimes, device binding, behaviour checks on every request
Log tampering	Append-only shipping, integrity hashes, separate log zone
Model poisoning or drift	Train on vetted data, scheduled retraining, monitor score distribution
Denial of service against the PDP	Rate limiting, decision cache, fail-safe defaults
False positives locking out users	Prefer Challenge before Block, analyst override, threshold tuning

Limitations: results come from a prototype with scripted and synthetic behaviour, so absolute figures will differ in real enterprise environments; weights and thresholds are initial settings and will be refined from the measured results.